API Security Testing Report – Forget Password API

Objective

Evaluate the security of the forget password endpoint responsible for sending password reset links.

Endpoint

POST https://stg-app.bosta.co/api/v2/users/forget-password

Testing Methodology

Security and validation testing was conducted using Postman by sending malformed inputs, invalid emails, and injection payloads to evaluate input validation and security protections.

Key Findings

- Email format validation enforced.
- API should prevent user enumeration.
- Injection payloads rejected.
- Large payload handling verified.

Conclusion

The API demonstrates basic input validation and protection against malformed inputs. Additional testing such as rate limiting and brute-force protection should also be considered.